

Password & Access Management Policy

Policy ID: IT-SEC-04

Owning area: IT

Policy owner: Head of Infrastructure & Security

Version: 4.0

Last reviewed: August 2026

Applies to: IronStore GmbH and all European subsidiaries

Purpose / Overview

This policy defines how IronStore creates, manages, reviews, and removes access to company systems and information. Its purpose is to reduce the risk of account compromise, unauthorised access, data loss, and operational disruption.

Access must be based on business need, limited to the minimum required level, and removed promptly when no longer required. IronStore uses central identity management, multi-factor authentication (MFA), role-based access controls, and periodic access reviews to support this policy.

Scope

This policy applies to:

- Employees, temporary staff, contractors, consultants, interns, and agency workers.
- Corporate accounts, privileged accounts, service accounts, and shared technical accounts.
- Company-managed laptops, mobile devices, virtual desktops, and approved personal devices used for work.
- Systems operated by IronStore or on its behalf, including:
 - Microsoft Entra ID and Microsoft 365.
 - Workday, SAP S/4HANA, and finance applications.
 - Shopify Plus, warehouse management systems, and logistics platforms.
 - AWS, Azure, GitHub Enterprise, Jira, Confluence, and Salesforce.
 - Customer support, marketing, payment, and analytics platforms.
- Third-party access to IronStore systems or data.

This policy does not replace system-specific security requirements. Where requirements conflict, the stricter requirement applies unless the CISO approves an exception.

Policy Statement and Procedures

1. Account and Identity Standards

Each person must use an individual IronStore account. Accounts must not be shared, transferred, or used by another person.

- Usernames follow the format `firstname.lastname@ironstore.eu`.
- HR must create or update the employee record before IT provisions access.
- Identity records must include the person's legal name, manager, department, employment status, and location.
- Accounts must be linked to a unique employee or contractor identifier.
- Personal email addresses must not be used for company accounts.
- Local administrator rights are prohibited unless approved under the Privileged Access Standard.
- Dormant accounts are disabled after 30 days without successful authentication.
- Disabled accounts are deleted or archived after 90 days, subject to legal hold and retention requirements.

IT Service Desk may create a temporary account only where the request includes a named owner, business reason, expiry date, and approving manager.

2. Password Requirements

Passwords must be resistant to guessing and must not be reused across company and personal services.

For systems that support modern authentication:

- Passwords must be at least 14 characters long.
- Passphrases of four or more unrelated words are recommended.
- Passwords must not contain the user's name, username, company name, product names, or common seasonal terms.
- Passwords must not appear in the 10,000 most commonly used passwords or known breach lists.
- Password managers approved by IT, currently 1Password Business, must be used for storing corporate credentials.
- Passwords must not be stored in browsers, spreadsheets, tickets, chat messages, or unencrypted files.
- Passwords must not be sent by email or communicated verbally.

Routine password changes are not required for standard accounts when MFA and risk-based controls are enabled. A password must be changed immediately if:

- The account may have been compromised.
- The password was disclosed, reused, or entered into an unapproved site.
- Security Operations instructs the user to change it.
- The system does not support MFA or is identified as high risk.

Systems that cannot support MFA must enforce a minimum 16-character password and a maximum password age of 180 days. Exceptions require written approval from the CISO.

3. Multi-Factor Authentication

MFA is mandatory for all externally accessible company systems and all administrative access.

- The preferred method is a FIDO2 security key or passkey.
- Authenticator applications using number matching are permitted.
- SMS may be used only as a temporary recovery method or where no stronger method is supported.
- Email-based one-time codes are not an approved primary MFA method.
- At least two MFA methods must be registered for employees with privileged or business-critical access.
- Recovery codes must be stored in the approved password manager or a secured physical location.
- Users must never approve an unexpected MFA prompt.
- Repeated unexpected prompts must be reported to the Service Desk or Security Operations immediately.

MFA resets require identity verification through the Service Desk. For privileged users, the reset must be approved by the user's manager or the on-call Security Operations lead.

4. Access Requests and Approval

Access is granted through the IronStore ServiceNow request catalogue. Requests must specify:

- The system, role, and access level requested.
- Business purpose and expected duration.
- The user's manager and cost centre.
- Any customer, payment, production, or personal-data access involved.

Standard access is approved by the line manager and the system owner. Sensitive or privileged access additionally requires approval from the relevant data owner. Production access, payment-system access, and access to customer exports require approval from both the system owner and the Head of Infrastructure & Security.

IT fulfils approved requests through Microsoft Entra ID groups, application roles, or the CyberArk Privilege Cloud platform. Direct permissions should not be assigned unless the system cannot support group-based access.

Target fulfilment times are:

- Standard employee access: one business day.
- New starter access: by 09:00 local time on the start date, if requested at least three business days in advance.
- Privileged or production access: two business days after all approvals are complete.
- Urgent access: only through the emergency access process.

5. Joiner, Mover, and Leaver Controls

HR is responsible for providing timely employment-status information to IT and the employee's manager.

Joiners

- HR submits the starter record at least three business days before the start date.
- The manager requests only the access required for the employee's initial duties.

- Accounts remain disabled until the start date unless an earlier date is approved by HR and IT.
- New users must complete security awareness training within 30 days.

Movers

- Managers must review access when an employee changes role, department, country, or reporting line.
- Access not required for the new role must be removed within one business day of the change.
- A new role must not be used to retain incompatible financial or operational permissions.
- System owners must resolve conflicting access identified by the quarterly review.

Leavers

- Involuntary termination: accounts, sessions, tokens, VPN access, and privileged credentials are disabled at the agreed termination time.
- Planned departure: access is removed no later than the employee's final working day.
- Company devices, security keys, and access badges must be returned.
- Shared mailbox and document ownership must be transferred to the manager.
- Service accounts, API keys, and automation owned by the leaver must be reassigned or rotated.

6. Privileged, Service, and Shared Accounts

Privileged access includes administrator, root, database owner, payment administrator, production deployment, and security-management roles.

- Privileged access must use a separate named administrator account.
- Administrative work must not be performed from a standard account where a privileged account is available.
- Privileged credentials must be stored and rotated through CyberArk.
- Privileged sessions must be logged where technically supported.
- Permanent standing access is prohibited for production systems unless the system owner documents the requirement.
- Just-in-time elevation should be used for cloud and infrastructure administration.
- Privileged access is reviewed monthly by the system owner and Security Operations.

Service accounts must have a named technical owner, documented purpose, system scope, and expiry or review date.

- Interactive sign-in is disabled unless technically necessary.
- Service-account passwords and API keys must be stored in an approved secrets vault.
- Credentials must be rotated at least every 180 days, or immediately following suspected exposure.
- Service accounts must not be used for personal work or ordinary user access.
- Shared human accounts are prohibited except where a system cannot support individual accounts.
- Approved shared accounts must have a documented owner, access list, MFA where supported, and quarterly review.

7. Access Reviews and Monitoring

System owners must review access according to the following schedule:

- Critical systems, production, payment, and customer-data platforms: quarterly.
- Other business applications: every six months.
- Privileged and emergency accounts: monthly.
- Service accounts and API credentials: quarterly.

Reviews must confirm that each user still has a valid business need, the assigned role is appropriate, and inactive or duplicate accounts are removed. Review results and remediation evidence must be retained in ServiceNow for at least three years.

Microsoft Entra ID, CyberArk, endpoint security tools, and key application logs are monitored by Security Operations. Alerts may include impossible travel, repeated failed logins, MFA fatigue, unusual privilege elevation, and access from blocked regions.

8. Lost Credentials and Suspected Compromise

Users must report suspected credential compromise immediately through the Service Desk, the Security Operations mailbox, or the emergency hotline listed on the IronStore intranet.

Users must:

- Stop using the suspected credential.
- Avoid deleting messages, files, or browser history related to the event.
- Disconnect a suspected device from the network if instructed.
- Follow password-reset and MFA-re-enrolment instructions.
- Not contact an external party or investigate beyond their normal duties.

Security Operations may disable accounts, revoke sessions, rotate secrets, block indicators, and preserve evidence. Suspected exposure of customer, payment, or employee data must be escalated to the Incident Manager and Data Protection Officer under the Information Security Incident Response Procedure.

9. Exceptions

Exceptions must be rare, time-limited, and documented in ServiceNow. The request must include:

- The requirement and affected system.
- Risk assessment and compensating controls.
- Named owner and expiry date.
- Approval from the system owner and CISO.

Exceptions expire after six months unless renewed. Critical risks may not be accepted solely by a system owner.

Roles & Responsibilities

- **All users:** Protect credentials, use MFA, follow approved access procedures, and report suspicious activity.
- **Line managers:** Request appropriate access, approve changes, and review access during role changes.
- **HR:** Maintain accurate joiner, mover, and leaver information.
- **IT Service Desk:** Verify identity, fulfil standard requests, and process account changes.
- **System owners:** Define roles, approve access, complete reviews, and remove unnecessary permissions.
- **Security Operations:** Monitor authentication activity, manage privileged controls, and investigate incidents.
- **CISO:** Own this policy, approve exceptions, and report material risks to the Risk Committee.
- **Data Protection Officer:** Advise on access to personal data and regulatory obligations.

Related Documents / References

- IT-SEC-01 Information Security Policy.
- IT-SEC-03 Privileged Access Standard.
- IT-SEC-06 Security Incident Response Procedure.
- IT-SEC-08 Acceptable Use Standard.
- IT-OPS-02 Joiner, Mover, and Leaver Procedure.
- IT-OPS-07 Third-Party Access Procedure.
- IronStore Data Classification and Handling Standard.
- IronStore Records Retention Schedule.
- ISO/IEC 27001:2022, Annex A controls 5.15–5.18 and 8.2–8.5.
- NIST SP 800-63B, Digital Identity Guidelines.

Revision History

- **August 2026 — Version 4.0:** Updated MFA requirements, passkey guidance, CyberArk controls, access-review frequencies, and emergency access process.
- **November 2024 — Version 3.2:** Added service-account ownership, API-key rotation, and customer-data access approvals.
- **May 2023 — Version 3.0:** Consolidated regional password standards and introduced Microsoft Entra ID as the primary identity provider.